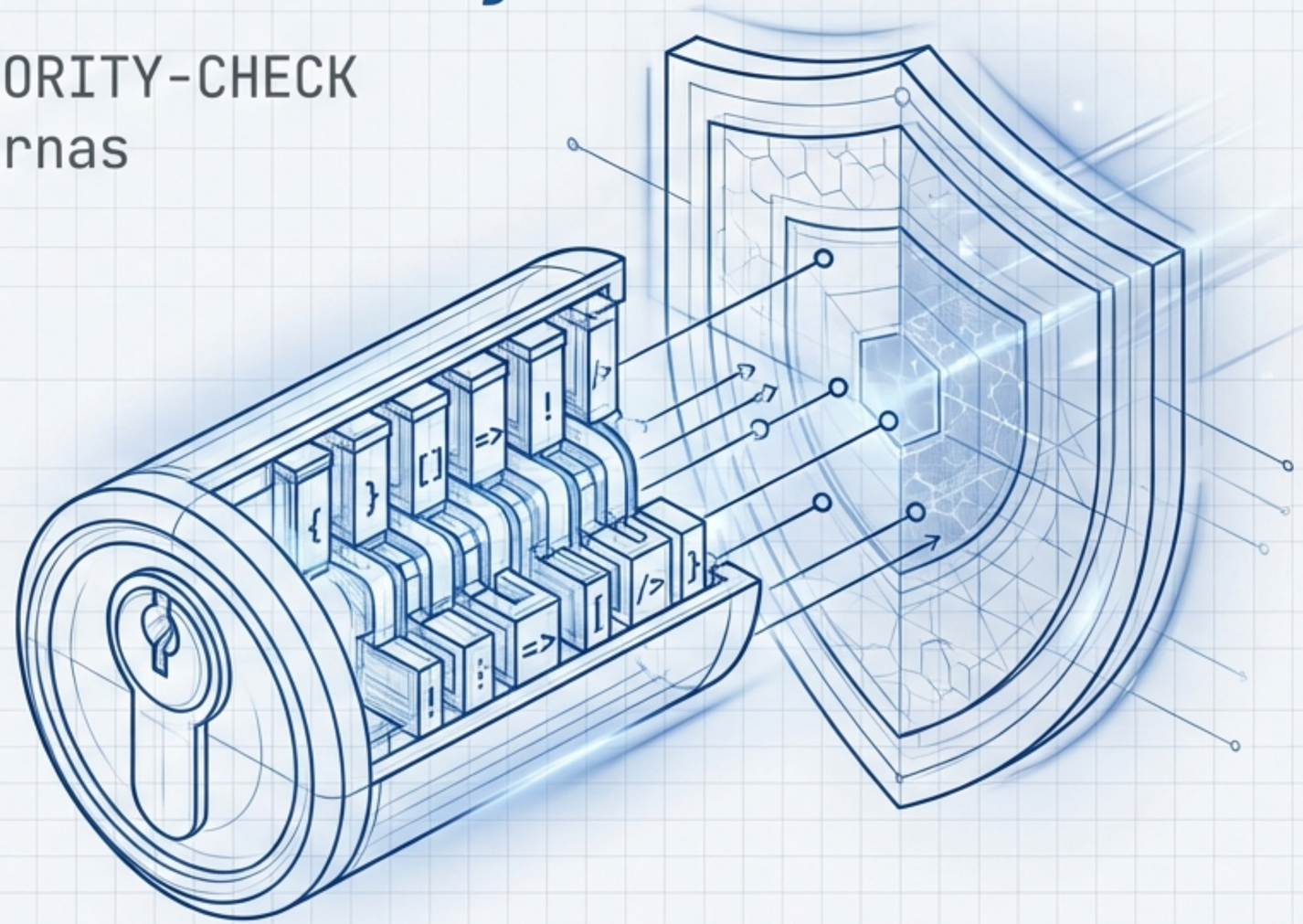
Segurança e Autorização no SAP

Implementando RBAC, AUTHORITY-CHECK e DCL em Aplicações Modernas



Arquitetura Técnica • ABAP • CDS • Security

NotebookLM

Objetivos da Jornada Arquitetural

Esta apresentação guia você do **conceito macro de arquitetura** até a **implementação técnica micro**, cobrindo:



Arquitetura RBAC

Compreender a hierarquia entre Usuários, Roles, Perfis e Objetos de Autorização.



Verificação Explícita (ABAP)

Implementar `AUTHORITY-CHECK` e tratar retornos (`sy-subrc`) para proteger ações.



Segurança de Dados (DCL)

Criar 'Row-Level Security' automático em CDS Views com `aspect pfcg_auth`.



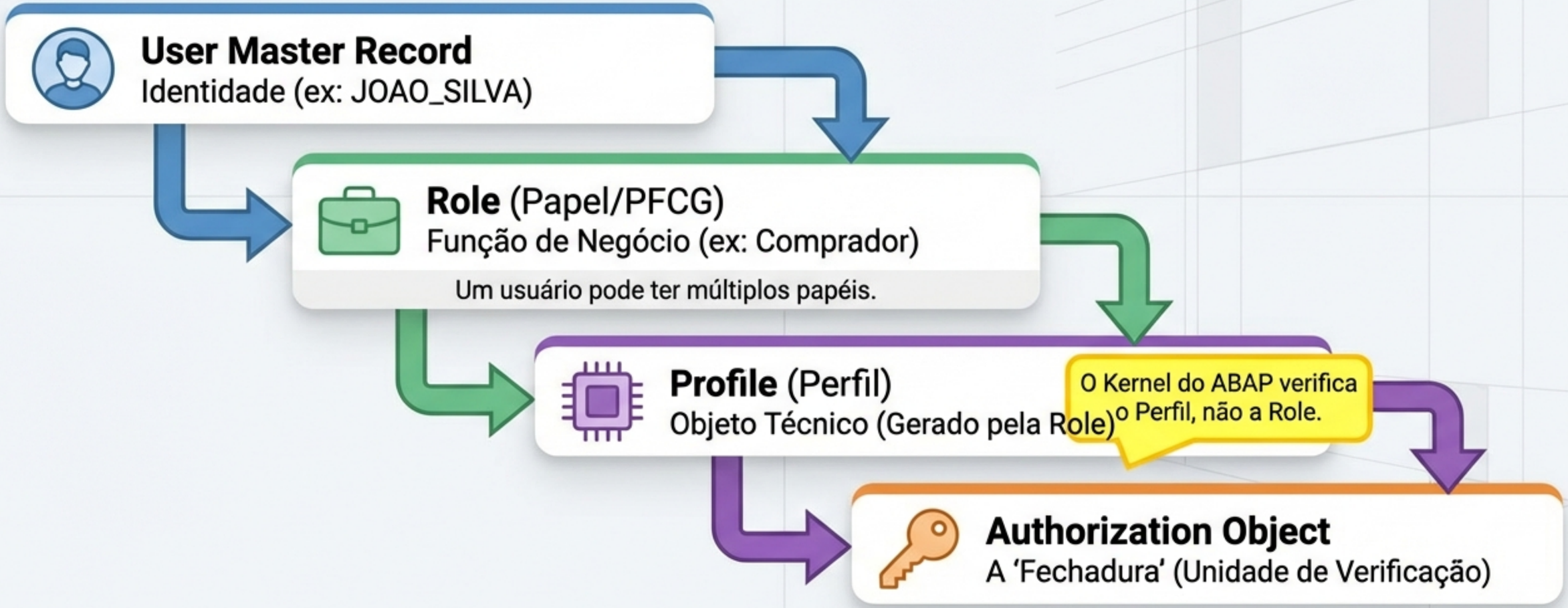
Diagnóstico

Utilizar SU53 e ST01 para resolver falhas de acesso.

NotebookLM

O Alicerce: Role-Based Access Control (RBAC)

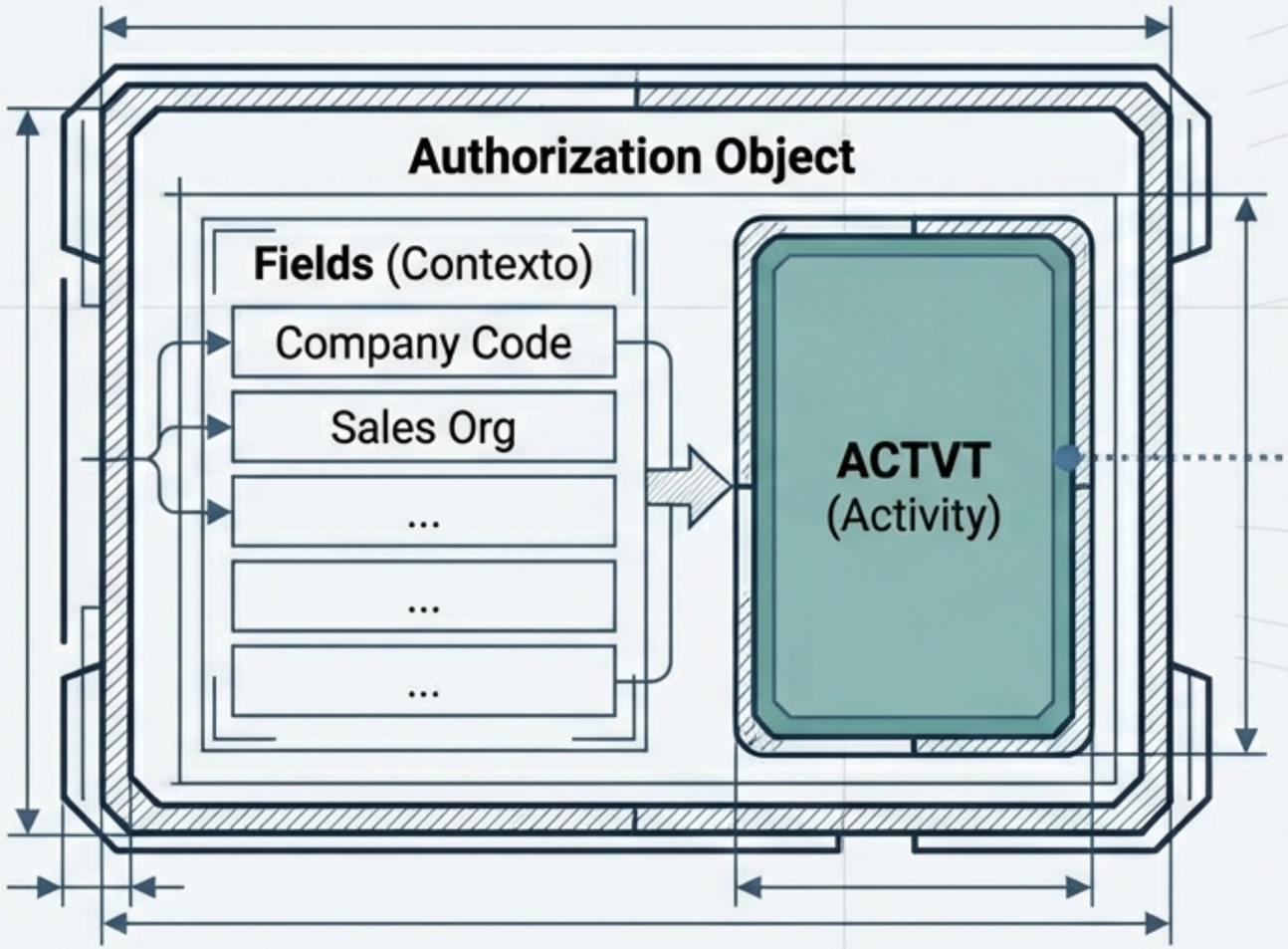
A segurança no SAP é granular e baseada em contexto, não binária. As permissões são agrupadas por função de negócio.



NotebookLM

A ‘Fechadura’: O Objeto de Autorização

Uma estrutura lógica (definida na SU21) que agrupa até 10 campos para definir o que proteger e como.



Valores Padrão de ACTVT

- “01”: Criar
- “02”: Alterar
- “03”: Exibir (Leitura Universal)
- “06”: Excluir

NotebookLM

Estratégia de Defesa: Aplicação vs. Dados

Segurança de Aplicação (Ação)



Posso clicar neste botão?
Posso executar este método?

Lógica processual (BAdIs, Ações RAP).

Verificação Explícita
(ABAP AUTHORITY-CHECK)

Segurança de Dados (Leitura)



Quais linhas eu posso ver
nesta lista?

Relatórios, Listas Fiori, Analytics.

Verificação Implícita
(CDS Access Control / DCL)

NotebookLM

Verificação Explícita: O Comando AUTHORITY-CHECK

Utilizado dentro de métodos ou BAdIs para consultar o buffer de autorizações do usuário.

```
AUTHORITY-CHECK OBJECT 'S_AGENCY'
  ID 'AGENCYNUM' FIELD '000001'
  ID 'ACTVT'     FIELD '02'.
```

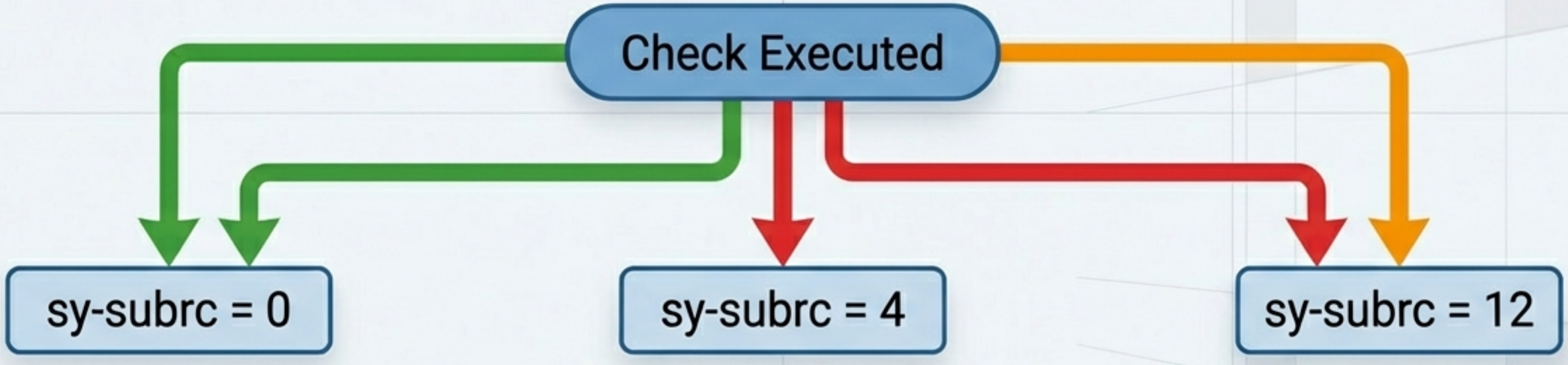
- Nome do Objeto (Definido na SU21)
- Valor específico a checar (Constraint)
- Atividade Requerida (02 = Alterar)

Atenção: Se um campo for omitido (Dummy Check), o sistema assume que *qualquer* valor é aceitável para aquele campo.

NotebookLM

O Veredito: Interpretando o sy-subrc

Falha Silenciosa: O `**AUTHORITY-CHECK**` não para o programa sozinho.
É mandatório checar o `**sy-subrc**`.



Sucesso / Green Light

O usuário tem permissão. O código prossegue.

Falha de Negócio / Red Light

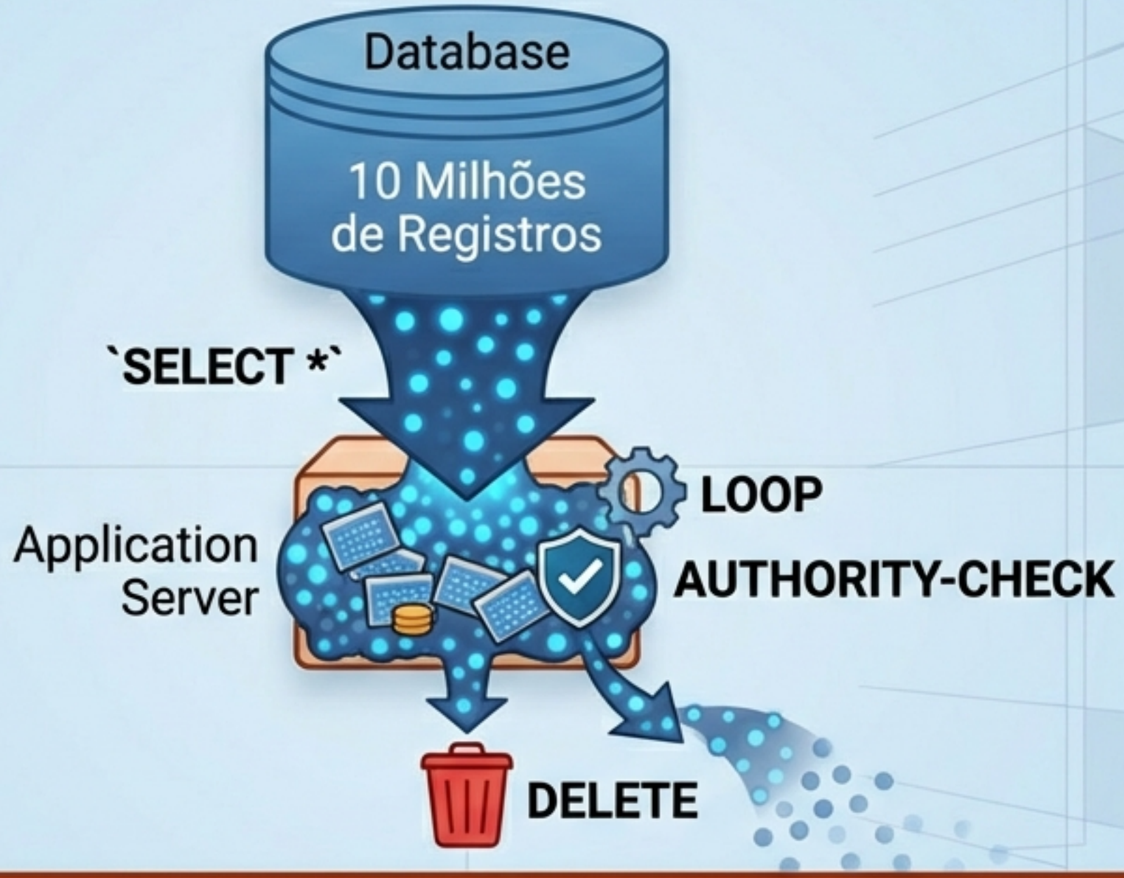
Bloquear processo e lançar exceção (ex: `cx_demo_auth_failure`).

Falha Técnica / Yellow Light

Objeto de autorização não existe. Reportar bug ao desenvolvedor.

NotebookLM

O Dilema da Performance (A Abordagem Antiga)

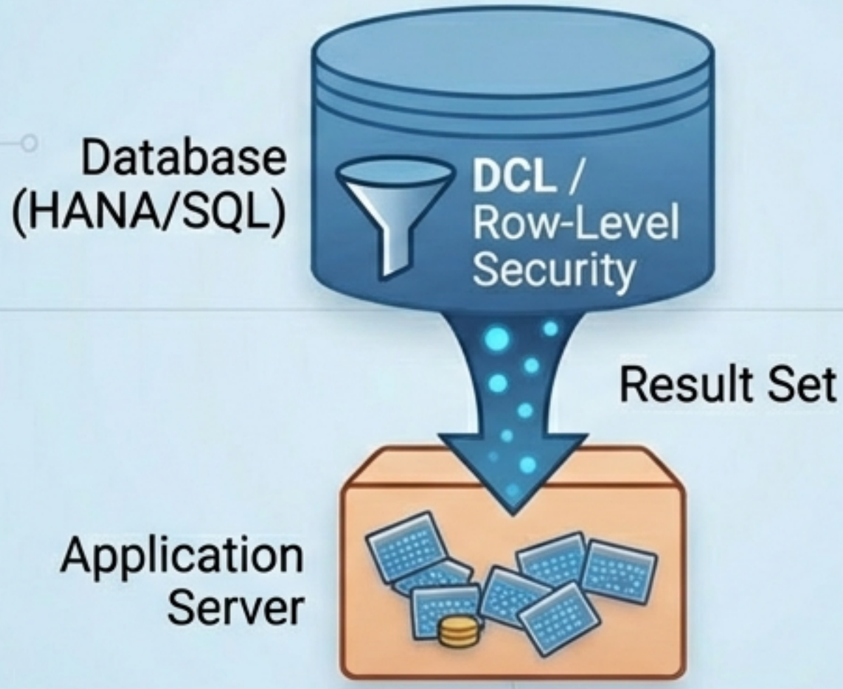


Impacto: Estouro de memória e lentidão.
O dado proibido trafegou desnecessariamente pela rede.

NotebookLM

A Solução Moderna: CDS Access Control (DCL)

Code Pushdown: A segurança é aplicada diretamente na consulta ao banco de dados.



Benefícios: Performance nativa e Segurança Universal (impossível de burlar por esquecimento).

NotebookLM

Anatomia do DCL (.dcls)

Um artefato separado que protege uma CDS View.

```
@MappingRole: true
define role Z_I_TRAVEL_DCL {
  grant select on Z_I_TRAVEL
  where ( AgencyID ) = aspect pfcg_auth( S_AGENCY,
                                         AGENCYNUM,
                                         ACTVT = '03'
                                         );

}
```

Objeto de Autorização.

A Mágica: Conecta dinamicamente os campos da View com os valores no perfil do usuário (PFCG).

Filtro Fixo (Apenas Leitura).

NotebookLM

DCL em Ação (Runtime)

Scenario: Usuário solicita dados de Viagens.

Query Original

```
SELECT *
FROM Travels
```

Database DCL Injection



User Role Check

Query Executada (Internal Rewrite)

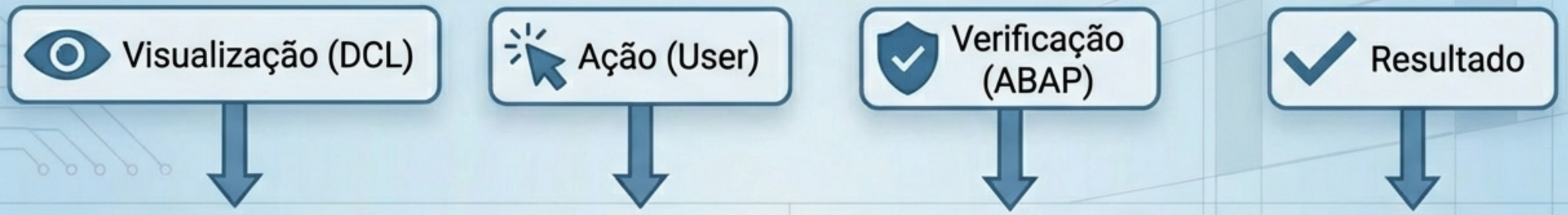
```
SELECT *
FROM Travels
WHERE Agency = 'Rio'
```

O **filtro** funciona como um `**WHERE**` dinâmico e invisível.

NotebookLM

Abordagem Híbrida: Exemplo Prático

Cenário: Usuário visualiza uma lista e tenta aprovar uma viagem.



Aprovação permitida somente se ambas as camadas validarem.

Use **ambas** as camadas **juntas** para cobertura completa.

NotebookLM

Batalha de Paradigmas: ABAP Check vs. DCL

Característica	AUTHORITY-CHECK (ABAP)	Access Control (DCL)
Local	Servidor de Aplicação	Banco de Dados (HANA/SQL)
Objetivo	Proteger uma **Ação** (Botão)	Filtrar **Dados** (Lista)
Performance	Lento para listas (Loops)	Rápido (Nativo no DB)
Comportamento	Explícito (Dev escreve IF)	Implícito (Automático)
Resultado	Código de erro (`sy-subrc`)	Conjunto de dados reduzido

NotebookLM

Diagnóstico e Troubleshooting

O que fazer quando o usuário relata 'Acesso Negado' ou 'Lista Vazia'.

SU53

O Primeiro Socorro

Verifica a *última* falha de autorização. Deve ser executada imediatamente após o erro.

ST01

O Investigador

System-wide Trace. Rastreia todas as verificações. Ideal para falhas silenciosas de DCL.

SACF

O Simulador

Permite simular cenários de verificação complexos sem alterar roles.

NotebookLM

Resumo e Glossário

Quiz de Fixação

Q: O que acontece sem um arquivo DCL?
R: Acesso total ('Full Access') aos dados.

Q: Qual o valor universal para leitura?
R: `ACTVT = '03'.

Q: Por que usar DCL?
R: 'Code Pushdown' e performance superior.

Glossário

- **ACTVT**: Define a operação (Criar, Alterar, Exibir).
- **PFCG_AUTH**: Função DCL para mapear campos do CDS contra o perfil.
- **SU53**: Transação para visualizar falhas de acesso.

"Segurança robusta é a combinação de arquitetura correta e código limpo."

NotebookLM